# КІБЕРБЕЗПЕКА ПЕРСОНАЛЬНОГО СМАРТФОНА

Принципи захисту пристрою, цифрових сервісів та користувацьких звичок

# Смартфон як центральний вузол цифрової ідентичності

## Проблема

- Смартфон перестав бути просто засобом зв'язку.
- Компрометація пристрою означає витік не заліза, а всієї цифрової особистості.
- Прямий доступ до токенів, паролів та платіжних систем.

## Причина та механізм

- Концентрація критичних сервісів: банківські додатки, пошта, 2FA-коди, фото, документи.
- Смартфон є ключем для скидання паролів від усіх зовнішніх акаунтів.
- Механізм: усвідомлення пристрою як накопичувача токенів доступу та побудова суворого контролю.

## Практичний приклад

Втрата незаблокованого смартфона з простим PIN-кодом.

Зловмисник через скидання пароля по SMS за 10 хвилин отримує доступ до месенджерів, пошти та банківського кабінету, зливаючи кошти та надсилаючи фішинг від імені власника.

# Масштаб загроз: Спроба атаки vs успішна компрометація

## Розуміння статистики загроз

• Спроба атаки (зовнішній шум):
- Отримано фішингове SMS або спам-дзвінок.
- Перегляд підозрілого посилання.
- Масова розсилка роботами (100,000+ спроб).

• Успішна атака (компрометація):
- Втрачено фінансові кошти.
- Зловмисник увійшов в акаунт або викрав дані.

• Мета кібербезпеки: не усунути шум, а зменшити ймовірність успіху до мінімуму.

## Реальний кейс: масовий фішинг

Сценарій:

Шахраї розсилають 100 000 SMS від імені поштової служби: 'Уточніть адресу доставки за посиланням'.

Результат:

• 99.5% спроб відсікаються фільтрами або критичним мисленням.

• Лише 0.5% недосвідчених користувачів вводять дані картки.

Висновок: Великий обсяг спаму не означає, що ваша система зламана.

# Модель трьох рівнів захисту смартфона

### 1. Захист пристрою

Конфігурація ОС та заліза:

- Складний PIN / Біометрія
- Автоматичне блокування
- Оновлення ПЗ та патчі
- Контроль дозволів додатків
- Захист SIM-картки

### 2. Захист сервісів

Криптографія та акаунти:

- Двофакторна автентифікація
- Застосунки-аутентифікатори
- Унікальні складні паролі
- Контроль активних сесій
- Ліміти на транзакції

### 3. Безпечна поведінка

Кібергігієна користувача:

- Критичне оцінювання SMS/дзвінків
- Перевірка URL-адрес сайтів
- Використання менеджерів паролів
- Нерозголошення OTP-кодів
- Аудит публікацій у соцмережах

# Рівень 1: Блокування екрана та автоблокування

## Механізми автентифікації

• Проблема: фізичний доступ до пам'яті та інтерфейсу.

• Графічний ключ: слабкий (легко зчитується за слідами на склі або через shoulder surfing).

• Простий PIN ('1234', '0000'): Підбирається за хвилини.

• Складний PIN (6+ цифр / пароль): рекомендований стандарт.

• Тайм-аут блокування: встановити 30–60 секунд. Чим коротший час, тим менше вікно для атак.

## Приклад із життя: Забутий пристрій

Сценарій:

Студент залишив телефон на декілька хвилин у студентському кафе чи аудиторії.

Захисний ефект:

Завдяки встановленому тайм-ауту автоблокування в 30 секунд екран загас до того, як сторонній користувач зміг переглянути особисті сповіщення чи відкрити банківський додаток.

# Рівень 1: Захист SIM-картки як ідентифікатора

### Вразливість SIM без PIN-коду

• Проблема: викрадення SIM-картки для перехоплення SMS.

• Причина: за замовчуванням PIN-код на SIM вимкнено або встановлено стандартний ('0000').

• Вектор атаки: зловмисник переставляє SIM у свій телефон і запитує скидання паролів від вашого Telegram, Gmail чи банку.

• Механізм захисту: встановлення унікального PIN-коду SIM-картки в налаштуваннях ОС.

### Реальний захист при викраденні

Сценарій:

Після крадіжки заблокованого смартфона зловмисник витягнув SIM-картку та вставив у свій телефон для отримання OTP-коду.

Результат:

Оскільки на SIM-картці стояв PIN-код, чіп вимагає розблокування при ініціалізації. Спроба перехопити SMS провалилася, надавши власнику час заблокувати номер у оператора.

# Рівень 1: Конфіденційність сповіщень та оновлення ПЗ

### Приховування сповіщень

• Ризик: push-повідомлення та SMS відображають свій вміст на заблокованому екрані.

• Наслідок: перегляд 6-значних OTP-кодів авторизації сторонніми особами без розблокування.

• Рішення: налаштувати режим 'Приховати чутливий вміст' у налаштуваннях сповіщень ОС.

### Актуальність ОС (N-day exploits)

• Ризик: робота на застарілій версії Android/iOS з відомими вразливостями.

• Причина: ігнорування системних сповіщень про оновлення.

• Механізм: виробники регулярно закривають прогалини безпеки. Оновлення ОС — це безкоштовний патч оборони.

# Рівень 1: Принцип мінімальних привілеїв для додатків

## Надлишкові дозволи (Over-privileged)

• Проблема: несанкціонований фоновий збір даних (камера, мікрофон, геолокація, SMS).

• Принцип Least Privilege: додаток має отримувати лише ті дозволи, які критично необхідні для його функціоналу.

• Маркери небезпеки:

- Калькулятор запитує доступ до контактів та SMS.
- Ліхтарик запитує точну геолокацію.
- Проста гра вимагає доступ до мікрофона у фоні.

## Реальний кейс: Додаток-ліхтарик

Сценарій:

Простий утилітарний додаток 'Flashlight' після чергового оновлення запросив доступ до читання SMS та геопозиції.

Реакція свідомого користувача:

Користувач скасував надлишкові дозволи, запобігши передачі фонових даних на рекламні сервери зловмисників.

# Розвінчання трьох поширених міфів мобільної безпеки

### Міф 1: Менеджери паролів

- Помилка: 'Небезпечно, бо всі паролі в одному місці'.
- Реальність: Менеджер генерує унікальні складні паролі для кожного сервісу та блокує автовведення на фішингових сайтах.

### Міф 2: Біометрія небезпечна

- Помилка: 'Обличчя легко підробити фотографією'.
- Реальність: Не плутайте 2D-камеру та апаратні 3D-сенсори з ІЧ-скануванням та захищеним модулем Secure Enclave.

### Міф 3: Антивірус захистить

- Помилка: 'Встановив антивірус — я в повній безпеці'.
- Реальність: Антивірус не захистить від добровільного введення пароля на фішинговому сайті чи передачі OTP шахраям.

# Рівень 2: Двофакторна автентифікація (2FA)

## Концепція двох факторів

• Фактор 1 (Знання): Пароль / PIN.

• Фактор 2 (Володіння): Застосунок TOTP / Апаратний ключ FIDO2 (YubiKey).

• Чому SMS — слабкий 2FA?

- Вразливість до SIM Swapping.
- Перехоплення через SS7 / IMSI Catcher.

• Стандарт: Використовувати Google Authenticator, 2FAS, Bitwarden або YubiKey.

## Приклад: Витік бази даних

Сценарій:

Внаслідок зламу стороннього форуму пароль користувача потрапив у відкритий доступ.

Результат:

Спроба зловмисників увійти в поштовий акаунт провалилася, оскільки сервіс запросив 6-значний код із застосунку-аутентифікатора на смартфоні.

# Рівень 2: Безпека мобільного банкінгу та платежів

## Ешелонування фінансових ризиків

• Ліміти на транзакції: встановлення добових та разових обмежень на онлайн-списання.

• Окрема віртуальна картка: використовувати спеціальну картку для покупок в інтернеті, поповнюючи її лише перед оплатою.

• Оперативні PUSH-сповіщення: миттєвий контроль кожної транзакції.

• Ревізія сесій: систематична перевірка активних підключень у банківському додатку.

## Реальний кейс: Підроблений магазин

Сценарій:

Користувач ввів дані картки на сумнівному сайті покупок. Магазин спробував списати $200.

Результат:

Транзакція була відхилена банком, оскільки ліміт для онлайн-оплат на цій картці дорівнював 0 грн і вмикався лише безпосередньо перед покупкою.

# Рівень 2: Атака SIM Swapping та перевидання номера

## Механіка атаки SIM Swapping

1. Зловмисник збирає персональні дані жертви (паспортні дані, подзвонені номери).
2. Звертається до мобільного оператора від імені жертви й перевидає SIM-картку.
3. Справжня SIM-картка втрачає мережу.
4. Зловмисник отримує всі SMS-коди та відновлює доступ до банку, пошти й Telegram.

## Методи захисту від SIM Swapping

- Прив'язка номера до паспорта.
- Заборона дистанційної заміни SIM у мобільного оператора (тільки особисто з паспортом).
- Відмова від SMS як єдиного другого фактора (перехід на TOTP/FIDO2).
- Перехід на eSIM з парольним захистом профілю.

# Рівень 3: Людський фактор та соціальна інженерія

## Психологічні тригери атак

• Страх та терміновість: 'Ваш акаунт заблокують через 15 хвилин!'

• Авторитет: Дзвінки від імені 'Служби безпеки банку' або 'Поліції'.

• Жадібність/Цікавість: 'Вам нараховано виплату, перейдіть за посиланням'.

• Правило кібергігієни:

Нікому й ніколи не передавати OTP-коди з SMS чи сповіщень. Офіційний банк ніколи не запитує коди підтвердження.

## Реальний кейс: Дзвінок з 'банку'

Сценарій:

Студенту зателефонували з невідомого номера, представившись службою безпеки банку, і повідомили про 'несанкціоноване списання'.

Реакція:

Студент поклав слухавку й сам передзвонив за офіційним номером, надрукованим на звороті картки. Спроба шахрайства провалилася.

# Практичний алгоритм аудиту безпеки смартфона

### Пристрій

[✓] Складний PIN (6+ цифр)
[✓] Біометрія увімкнена
[✓] Автоблокування ≤60 сек
[✓] Встановлено PIN на SIM
[✓] Сповіщення приховані
[✓] ОС оновлена
[✓] Ревізія дозволів додатків

### Акаунти

[✓] Увімкнено 2FA (TOTP)
[✓] Унікальні паролі
[✓] Менеджер паролів
[✓] Перевірено активні сесії
[✓] Ліміти в банку встановлені
[✓] Віртуальна картка для інету

### Поведінка

[✓] Перевірка URL адрес
[✓] Відмова від публічного Wi-Fi без VPN
[✓] Критичне ставлення до SMS
[✓] Заборона передачі OTP
[✓] Контроль даних у соцмережах

# Ключові висновки

1. Абсолютного захисту не існує.

Головна мета кібербезпеки — підвищити вартість та складність атаки для зловмисника вище потенційної вигоди.

2. Синергія трьох рівнів.

Захист — це ланцюг, міцність якого визначається найслабшою ланкою (Пристрій + Сервіси + Поведінка).

3. Безпека — це постійний процес, а не одноразова настройка.

Регулярні оновлення, ревізія дозволів та критика до нових векторів атак є обов'язковими для IT-фахівця.

# Контрольні питання та завдання

## Контрольні питання

1. В чому різниця між спробою атаки та успішною компрометацією?
2. Чому графічний ключ є слабким елементом аутентифікації?
3. Як PIN-код на SIM-картці захищає від відновлення паролів?
4. У чому полягає ризик використання SMS як 2FA?
5. Опишіть механіку та захист від атаки SIM Swapping.

## Завдання

1. Налаштувати автоблокування (≤60 с) та приховати вміст сповіщень.
2. Встановити PIN-код на SIM-картку та перевірити роботу при перезавантаженні.
3. Провести ревізію дозволів додатків (скасувати доступ до геолокації/мікрофона).
4. Увімкнути 2FA через Authenticator (TOTP) для пошти та Telegram.
5. Провести аудит активних сесій та завершити застарілі.